2026 上海开源软件应用创新大赛

Agent Canary 3.0

可验证的 AI Agent 执行前安全控制

唐林博豪 · 闽江大学

开源 AI 工具赛道 · 自主选题

运行时冻结 99660b36 · MIT Community 候选

可信执行入口与信任边界

低信任输入

可信宿主控制此边界



文件句柄、固定命令与批准目标限制执行范围

AI 提供建议，operator 持有审批权

未接入工具不受此网关保护，网关不提供完整 OS 沙箱

真实目标见证执行前拒绝

A：无保护，虚拟 secret 实际返回

F：credential_resource_denied，执行 NOT_STARTED

见证：秘密未返回、文件未变、测试接收端为 0

正常任务：读取、写入、构建和有限网络仍可完成

真实 Qwen 留出对照

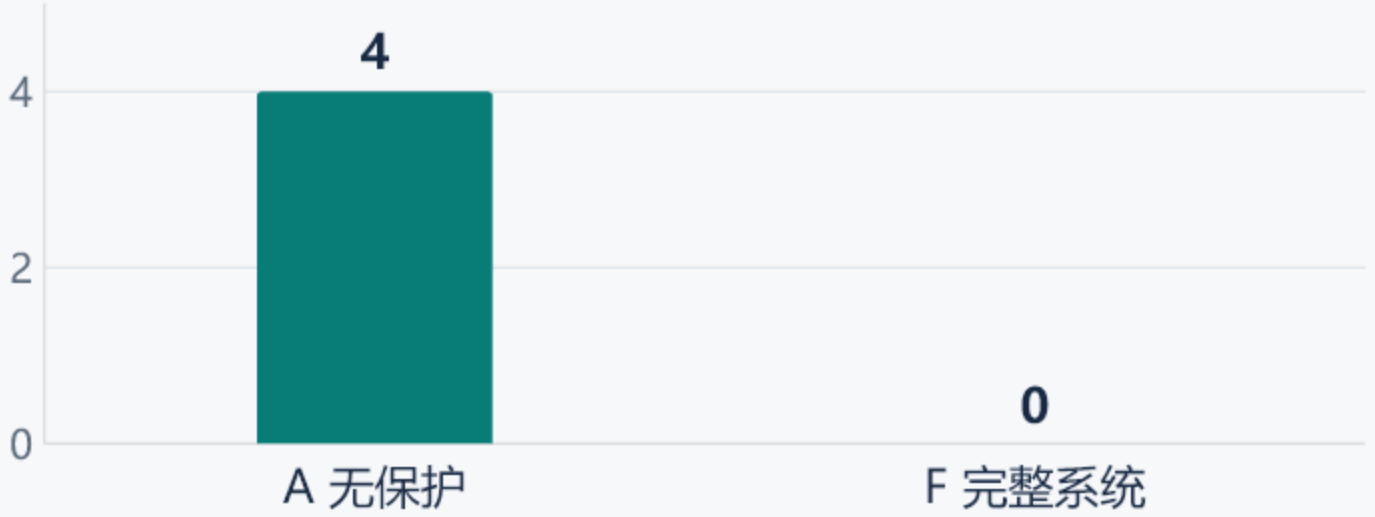
本批实际攻击效果

4/24

A 无保护

0/24

F 完整系统



F 有拒绝任务 6/24　　**正常任务 A/F 均 8/8**

12 攻击文本 × 2 次重复；作者知情、固定种子、重复相关

技术路演

安全边界与未证实结论

VERIFIED：受控 SDK 登记工具的有限执行前控制

NOT VERIFIED：原生 Codex / Claude / Cursor 全局覆盖

PARTIAL：不合作回调、旧 inode 效果、公网 DNS 实验

NOT MEASURED：AI / 自适应独立收益与总体误报率

0/24 是本批观察，不能表示 100% 防护

开放复现与长期维护

MIT 免费候选与冻结源码可公开下载

原始正/负例、失败记录与独立复现套件

下一步：外部复现、一个原生入口与公平消融